

Guía breve de lecturas — Semana 05

Seguridad y gobernanza

Computación en Nube · EAFIT · 5 de octubre de 2026

Objetivo. Preparar la discusión de seguridad siguiendo una cadena de decisión: identidad → principal → Action → Resource → Condition → allow / deny → protección del dato → trazabilidad. La meta no es memorizar servicios ni sintaxis extensa de IAM JSON, sino distinguir autorización, cifrado y auditoría mediante comportamiento y evidencia.

Carga esperada: 20–24 minutos para las tres lecturas prioritarias. No hay entrega independiente; use la preparación para interpretar decisiones de autorización y la evidencia del Lab Evolutivo 05.

PREGUNTAS ORIENTADORAS

- Si una EC2 puede llegar al endpoint de S3, ¿por qué todavía puede recibir AccessDenied al intentar leer un objeto?
- ¿Qué evidencia necesitarías para distinguir entre un problema de reachability, identidad, Resource fuera de alcance o Action no concedida?
- ¿Por qué verificar que un objeto está cifrado no demuestra que esté correctamente autorizado?
- ¿Qué campos de un evento de CloudTrail usarías para explicar quién realizó un cambio administrativo y cuándo?

LECTURA PRIORITARIA 1

AWS IAM — Roles, temporary credentials y least privilege

Qué leer: en “Security best practices in IAM”, revise únicamente “Require workloads to use temporary credentials with IAM roles to access AWS” y “Apply least-privilege permissions”. En “IAM roles”, lea la definición de role y su relación con temporary security credentials. Quédese con el patrón workload → role → credenciales temporales → permisos mínimos.

Qué no leer: creación exhaustiva de IAM users, access keys como patrón de aplicación, federation avanzada, IAM Identity Center en profundidad, permissions boundaries, ABAC avanzado ni evaluación cross-account detallada.

Para qué: entender por qué una instancia EC2 debe obtener credenciales temporales mediante un IAM Role en lugar de almacenar access keys de larga duración, y por qué least privilege se ajusta a los permisos mínimos que exige una tarea.

Tiempo estimado: 7–8 minutos.

Abrir: [IAM — Security best practices](#) · [IAM — Roles](#)

LECTURA PRIORITARIA 2

AWS IAM — Policies: Action, Resource y alcance

Qué leer: en “Policies and permissions in IAM”, revise Effect, Action, Resource y Condition a nivel conceptual. Luego lea “Identity-based policies and resource-based policies” solo para ubicar dónde puede expresarse una autorización. Interprete cada statement como quién puede hacer qué, sobre cuál recurso y bajo qué condición.

Qué no leer: sintaxis completa de IAM JSON, policies complejas multi-statement, evaluación avanzada entre accounts, SCP en detalle, permissions boundaries, KMS key policies ni grants.

Para qué: explicar el comportamiento del Lab 05 sin atribuirlo a networking: en ese escenario, s3:GetObject sobre allowed/* está dentro del alcance permitido; la misma lectura sobre restricted/* o s3:PutObject sobre allowed/* queda fuera del permiso concedido y produce AccessDenied.

Tiempo estimado: 7–8 minutos.

Abrir: [IAM — Policies and permissions](#) · [IAM — Identity vs resource policies](#)

LECTURA PRIORITARIA 3

AWS CloudTrail — Event history y trazabilidad

Qué leer: en “Working with CloudTrail event history”, revise qué muestra Event history y su límite a management events. En “CloudTrail record contents”, ubique userIdentity, eventName, eventTime y requestParameters. Use AttachRolePolicy o PutBucketPolicy como ejemplos de cambio administrativo. Distinga explícitamente: PutObject es un S3 data event y no debe asumirse visible en Event history por defecto.

Qué no leer: creación de trails, data event selectors, CloudTrail Lake, integración SIEM, CloudWatch alarms, dashboards ni observabilidad operativa profunda.

Para qué: entender que el logging no previene una acción. CloudTrail permite atribuir actividad administrativa, reconstruir quién hizo qué y cuándo, y conservar evidencia para investigación o auditoría.

Tiempo estimado: 6–8 minutos.

Abrir: [CloudTrail — Event history](#) · [CloudTrail — Event record contents](#) · [CloudTrail — Management vs data events](#)

CIERRE

Llegue a la sesión pudiendo explicar cuatro controles distintos: la red determina si puede llegar; IAM determina si puede ejecutar la acción; el cifrado protege el dato; CloudTrail deja evidencia de acciones administrativas.

Transición hacia S06: Ya controlamos quién puede hacer qué. Ahora necesitamos saber qué está ocurriendo y hacer la operación repetible.

Frontera de esta semana. Manténgase en IAM roles, temporary credentials, least privilege, policies, Action/Resource/Condition, cifrado y secrets a nivel conceptual, y CloudTrail/audit. No avance hacia CloudWatch metrics/alarms, dashboards, IaC, CI/CD, Secrets Manager hands-on, KMS avanzado, Organizations/SCP hands-on, GuardDuty, Security Hub ni WAF.